

GDPR Data Handling Assessment

Scenario: Customer Financial Dataset

A financial services company holds a customer dataset containing names, email addresses, account numbers, transaction values and dates. The dataset is used to analyse customer activity and produce internal financial reports. Because the dataset contains information relating to identifiable individuals, appropriate GDPR controls must be applied when collecting, storing, accessing and analysing the data.

1. Personal Data Identification

The dataset contains personal data because names, email addresses and account numbers can be linked to identifiable individuals. Transaction information may also reveal information about a customer's financial activity. This data should therefore be handled securely and only used for legitimate and specified purposes.

2. Application of GDPR Principles

Lawfulness, Fairness and Transparency: The organisation should have an appropriate lawful basis for processing the customer data and clearly explain how the information will be used through a privacy notice.

Purpose Limitation: Customer data collected for financial reporting and analysis should only be used for those specified purposes unless there is a valid basis for further processing.

Data Minimisation: Only the information necessary for the analysis should be used. For example, customer names and email addresses could be removed from an analytical dataset when they are not required.

Accuracy: Customer information should be kept accurate and corrected when errors are identified.

Storage Limitation: Personal data should not be retained indefinitely. The organisation should establish appropriate retention periods and securely delete or anonymise information when it is no longer required.

Integrity and Confidentiality: Personal data should be protected using appropriate security measures, such as access controls, strong authentication, encryption where appropriate, and restricting access to authorised employees.

3. Practical Data Handling Controls

If I were working with this customer dataset as a data analyst, I would take the following steps to reduce privacy and security risks:

1. Remove direct identifiers such as customer names and email addresses when they are not required for the analysis.
2. Replace customer identifiers with anonymous or pseudonymous IDs where appropriate.
3. Only access the minimum amount of customer data necessary to complete the task.
4. Store the dataset in an approved secure location rather than on personal devices or unsecured storage.
5. Restrict access to authorised individuals who require the data for their role.
6. Avoid sharing raw customer data through unsecured channels.
7. Follow the organisation's retention policy and securely delete data when it is no longer required.
8. Report a suspected personal data breach immediately through the organisation's established incident-reporting procedure.

4. Data Subject Rights and Breach Awareness

Under UK GDPR, individuals have rights relating to their personal data. Depending on the circumstances, these can include the right to be informed, the right of access, the right to rectification, the right to erasure, the right to restrict processing, the right to data portability and the right to object.

If a personal data breach occurred, I would not attempt to conceal or independently resolve the incident. I would report it immediately through the organisation's established procedure so that the incident could be assessed, contained and, where required, reported to the relevant supervisory authority and affected individuals.

5. Conclusion

This assessment demonstrates my foundational understanding of GDPR and how data protection principles can be applied when handling customer and financial datasets. The key considerations are limiting unnecessary personal data, maintaining appropriate security, controlling access, following retention requirements and respecting individuals' data protection rights.

